

Hi IT Manager,

Thank you for your patience and time whilst we put this report together. I have included a list of recommendations below that we encourage you to consider and implement.

For ease of use, I have ordered the recommendations by priority, based on the level of risk posed alongside the estimated cost and/or time required for implementation.

If you have any questions or concerns regarding any of the recommendations or their implementation, please do not hesitate to contact me directly for further support.

Kind Regards,

Dan

1. Access Control - Critical Priority

All Botium Toys employees currently have access to internally stored data and may be able to access cardholder data and customer PII/SPII.

Suggested fix:

I'd recommend implementing formal user access controls and access policies so that sensitive systems and data can only be accessed by authorised users. Access should be granted, reviewed and removed through a documented process.

2. Encryption - Critical Priority

Issue:

Botium Toys does not currently use encryption to protect customers' credit card information when it is accepted, processed, transmitted, or stored in the internal

database. If this data were exposed, an attacker could read or misuse customers' payment information.

Suggested fix:

Implement encryption for sensitive payment and customer data both at rest and in transit, so intercepted or stolen data cannot be easily read. Use a TLS certificate to secure the website with HTTPS, protecting payment data in transit, while also encrypting sensitive data stored in the internal database. Free TLS certificates are available from Let's Encrypt.

3. Least Privilege - High Priority

Issue:

Botium Toys has not implemented least privilege, meaning employees may have more access to systems and sensitive data than they actually need for their role.

Suggested fix:

Restrict each user to the minimum level of access required to perform their job. Elevated permissions should only be granted where necessary and reviewed regularly.

Example:

A warehouse employee may need access to inventory systems, but should not be able to access customer payment information.

4. Separation of Duties - High Priority

Issue:

Botium Toys has not implemented separation of duties, meaning one employee could potentially have too much control over a sensitive process.

Suggested fix:

Split sensitive or high-risk tasks between different employees so that no single person can complete an entire critical process without oversight or approval. Separate roles should be created for initiating, approving and reviewing sensitive actions. Active Directory groups can help enforce these separate permissions.

Example:

If one employee creates a supplier payment or changes a supplier's bank details, a different authorised employee should be required to review and approve the change before the payment can be processed.

5. Backups - High Priority**Issue:**

Botium Toys currently has no backups of critical data, meaning important business information could be permanently lost if systems are damaged, corrupted, deleted, or compromised. Corruption can happen even if you've done everything right, sometimes machines and systems just go wrong.

Suggested fix:

Implement regular, automated backups of critical systems and data, with copies stored separately from the main network. Backups should also be tested periodically to make sure they can actually be restored.

Example:

If ransomware encrypted Botium Toys' internal intranet/database, a recent offline or cloud backup could allow the company to restore customer and business data without relying on the compromised system.

6. Disaster Recovery - High Priority

Issue:

Botium Toys currently has no disaster recovery plan in place, meaning there is no documented process for restoring systems and services after a major incident.

Suggested fix:

Create and document a disaster recovery plan that defines recovery priorities, staff responsibilities, recovery procedures, and how critical systems will be restored. The plan should also be tested regularly.

Example:

If a fire or major hardware failure took the main office systems offline, the disaster recovery plan would give IT a clear process for restoring essential services in the correct order.

7. Password Security - High Priority

Issue:

Botium Toys has a password policy, but the current requirements are weak and do not meet the minimum complexity standards described in the report.

Suggested fix:

Strengthen the password policy by enforcing longer passwords and requiring a mix of letters, numbers, and special characters. This can be done via Active Directory.

Example:

Instead of allowing a simple password such as **Toys123**, staff could be required to use a stronger password such as a longer passphrase with mixed character types. In an offline password attack, a short and predictable password such as Toys123 could potentially be cracked very quickly. A much longer password such as !Rand0m4pple9031! would be substantially more resistant to pure brute force.

However, predictable words and character substitutions can still reduce password strength, so long, unique passphrases or randomly generated passwords are preferable.

8. Password Management System - Medium/High Priority

Issue:

Botium Toys does not currently have a centralised password management system, so password requirements are not being consistently enforced across users and vendors.

Suggested fix:

Implement a centralised password management solution that can enforce the company's password policy, support secure password resets, and reduce reliance on manual IT intervention.

Example:

If an employee forgets their password, a centralised system could allow a secure reset while still enforcing the company's minimum password requirements, rather than IT manually creating or accepting a weaker replacement password. Microsoft Entra ID or Microsoft Active Directory could be used as centralised identity and account management systems to enforce password policies and securely manage user accounts.

9. Intrusion Detection System (IDS) - Medium/High Priority

Issue:

Botium Toys currently doesn't have an intrusion detection system in place, meaning suspicious or potentially malicious activity may go unnoticed until after damage has already occurred.

Suggested fix:

Deploy an IDS to monitor network traffic and system activity for unusual patterns,

known attack signatures, or other indicators of compromise, with alerts sent to IT for investigation.

Example:

If an attacker began repeatedly probing internal systems or attempting suspicious connections, an IDS could detect that behaviour and alert the IT team before the activity escalates. Traditional antivirus likely won't detect this type of network activity, whereas an IDS is specifically designed to monitor traffic and identify suspicious patterns or known attack signatures.

10. Asset and Data Classification - Medium Priority

Issue:

Botium Toys doesn't have a complete understanding of which assets and data are most critical or sensitive. The report specifically says the IT department needs to identify and classify assets, and currently does not know which assets would be at risk.

Suggested fix:

Create and maintain an up-to-date inventory of hardware, software, systems, and sensitive data, then classify them by importance, cost and sensitivity. This helps IT decide which assets need the strongest controls and which systems should be prioritised during an incident. Higher-risk assets can then be given stronger security controls or greater network isolation where appropriate.

Example:

Customer payment data could be classified as highly sensitive, while something like a standard office printer would be low sensitivity, meaning security resources can be focused where the impact of compromise would be greatest.

11. Legacy System Monitoring - Medium Priority

Issue:

Whilst the report does suggest Botium Toys actively monitor and maintain its legacy systems, the report also suggests there is no regular schedule in place and the methods for intervention are unclear.

Suggested fix:

Create a documented maintenance and monitoring schedule for legacy systems, including who is responsible for checks, what needs to be reviewed, and what action should be taken if a problem is found.

Example:

If an older server is still required for a critical business function, IT could schedule monthly health and security checks so faults or vulnerabilities are identified before the system fails unexpectedly.

12. Existing Controls - Low Priority**Issue:**

Botium Toys already has several effective controls in place, including a firewall, regularly monitored antivirus software, locks, CCTV, and fire detection/prevention systems. These do not need urgent replacement, but they still need ongoing maintenance and review.

Suggested fix:

Keep these controls updated, tested, and reviewed on a regular schedule so they continue to work effectively as the business and threat landscape change. As an additional consideration, Botium Toys could review whether access badges and staff awareness training on risks such as shoulder surfing and tailgating would be appropriate.

Example:

The firewall should have its rules reviewed periodically to make sure outdated or unnecessary access is removed and only required network traffic is allowed.